Write-Up: Bounty Hacker

Plataforma: TryHackMe | **Dificuldade:** Fácil
Data de Resolução: 22/04/2026

Sumário

1. Visão Geral

2. Reconhecimento

3. Exploração

4. Escalada de Privilégios

5. Conclusão

6. Referências

1. Visão Geral

O desafio Bounty Hacker explora falhas de configuração em serviços comuns (FTP) e a má gestão de arquivos sensíveis. A invasão baseia-se em uma coleta de informações (OSINT) dentro do próprio servidor para realizar um ataque de força bruta no SSH e, posteriormente, abusar de permissões sudo em binários nativos do sistema.

2. Reconhecimento

A enumeração inicial via `nmap` revelou três serviços principais:

nmap -sV <IP_alvo>

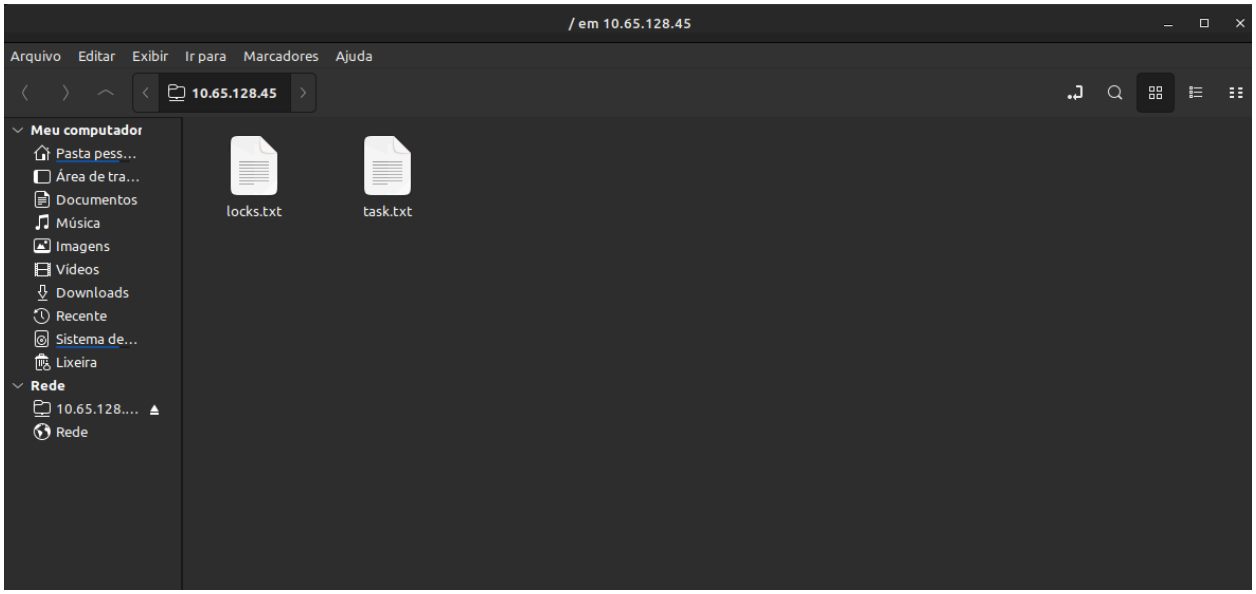
```
→ ~ nmap -sV 10.65.128.45
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-24 22:40 -03
Nmap scan report for 10.65.128.45
Host is up (0.16s latency).
Not shown: 967 filtered ports, 30 closed ports
PORT    STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.89 seconds
```

Serviços Identificados:

- **Porta 21 (FTP):** vsftpd 3.0.3. Login anônimo habilitado.
- **Porta 22 (SSH):** OpenSSH 7.2p2.
- **Porta 80 (HTTP):** Apache httpd 2.4.18.

Ao explorar o FTP anônimo, encontrei dois arquivos:

1. `task.txt`: Mencionava um autor chamado "lin"(resposta de uma das questões do CTF).
2. `locks.txt`: Uma lista de possíveis senhas.



task.txt (10.65.128.45 /)

Arquivo Editar Ver Pesquisar Ferramentas Documentos Ajuda

task.txt

```
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

locks.txt (10.65.128.45 /)

Arquivo Editar Ver Pesquisar Ferramentas Documentos Ajuda

task.txt locks.txt

```
rEddrAGON
ReDdr4g0nSynd!cat3
Dr@gOn$yn9icat3
R3DDr46ONSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynDIc4te
R3Dr4gOn2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdragOn$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@gOn$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@goN5YNd1c@73
rEDdrAGOnSyNDiCat3
r3ddr@g0N
ReDSynd1ca7e
```

3. Exploração

Com o nome de usuário potencial (`lin`) e a wordlist obtida (`locks.txt`), realizei um ataque de força bruta contra o serviço SSH utilizando o **Hydra**:

```
hydra -l lin -P locks.txt ssh://<IP_alvo>
```

Raciocínio Técnico: A falha aqui foi a exposição da wordlist no FTP anônimo, o que permitiu o sucesso do ataque de força bruta. Após obter a senha correta, estabeleci a conexão:

```
ssh lin@<IP_alvo>
```

4. Escalada de Privilégios

Após o acesso inicial, realizei a enumeração local em busca de vetores de escalada. Identifiquei que o sistema era vulnerável ao **PwnKit (CVE-2021-4034)**, uma falha de corrupção de memória no componente pkexec do Polkit.

A exploração foi realizada executando um exploit local codificado em C(verifiquei que a máquina possuia o compilador gcc) que manipula as variáveis de ambiente para forçar a execução de um shell com privilégios elevados, o que me levou a obter privilégios de root e concluir o CTF.

5. Conclusão

A exploração demonstrou a importância de restringir o acesso anônimo a serviços e proteger arquivos que possam auxiliar em ataques de força bruta. A escalada de privilégios foi possível devido a uma vulnerabilidade na ferramenta pkexec, viabilizando o acesso a um shell de root. Vale lembrar que também era possível escalar privilégios por meio da exploração do binário tar, que pode ser utilizado para executar comandos com privilégios de root no sistema.

6. Referências

- **Hydra Documentation:** https://www.kali.org/tools/hydra/
- **Exploit - PkExec:** https://github.com/ly4k/PwnKit/blob/main/PwnKit.c